

РЕГЛАМЕНТ

3_Регламент_реагирования_на_инциденты.md

реагирования на инциденты, связанные с персональными данными

Утверждён: «» _ 2026 г. **Основание:** части 3.1 и 3.2 статьи 21, статья 19 Федерального закона от 27.07.2006 № 152-ФЗ.

1. Назначение

Регламент устанавливает порядок действий при выявлении инцидента, повлёкшего неправомерную или случайную передачу (предоставление, распространение, доступ) персональных данных и нарушение прав субъектов персональных данных.

Ключевой факт: Роскомнадзор, как правило, не применяет санкции за сам факт инцидента, если оператор уведомил в установленные сроки и документально подтвердил принятые меры. Ответственность наступает за **несвоевременное уведомление либо сокрытие** — часть 11 статьи 13.11 КоАП РФ, для юридических лиц от 1 до 3 млн рублей. Настоящий Регламент — инструмент снижения санкции, а не формальность.

2. Что считается инцидентом

Тип	Примеры
Неправомерный доступ	Несанкционированный вход в систему; доступ к заданию другого пользователя
Компрометация аутентификационных данных	Раскрытие токена, ключа доступа, пароля
Утечка результата или ключа	Передача таблицы соответствий не тому получателю; публикация
Инцидент у привлечённого лица	Уведомление от ООО «ИНТЕРФОНИКА» о происшествии на их стороне
Компьютерная атака	Успешная эксплуатация уязвимости; вредоносное программное обеспечение
Утрата носителя	Утрата или хищение оборудования с персональными данными

Не является инцидентом, требующим уведомления: неудачные попытки доступа без результата; сбой, не повлёкший раскрытия данных; выявление уязвимости до её эксплуатации. Такие события фиксируются в журнале без уведомления регулятора.

3. Сроки — критически важно

Срок	Что направляется	Норма
24 часа с момента выявления	Уведомление о произошедшем инциденте, о предполагаемых причинах, повлёкших нарушение прав субъектов, и предполагаемом вреде; о принятых мерах по устранению последствий; сведения о лице, уполномоченном на взаимодействие с уполномоченным органом	Пункт 1 части 3.1 статьи 21
72 часа с момента выявления	Уведомление о результатах внутреннего расследования; сведения о лицах, действия которых стали причиной инцидента (при наличии)	Пункт 2 части 3.1 статьи 21

Отсчёт ведётся с момента выявления, а не с момента возникновения. Момент выявления фиксируется письменно немедленно.

4. Порядок действий

Час 0 — выявление

Зафиксировать дату и точное время выявления, источник сведений, признаки инцидента. Не предпринимать действий, уничтожающих следы: журналы, дампы, конфигурации сохранить.

Часы 0–4 — локализация

Прекратить обработку в затронутом контуре. Отозвать скомпрометированные ключи и токены. Ограничить доступ. Зафиксировать все действия с указанием времени.

Часы 0–12 — оценка

Установить: какие категории персональных данных затронуты; ориентировочное число субъектов; состоялся ли фактический доступ третьих лиц; является ли оператором Заказчик — и если да, **уведомить Заказчика немедленно** (для него это его собственный инцидент, и у него свои 24 часа).

Час 24 — первичное уведомление

Направить уведомление в Роскомнадзор по форме раздела 6.

Часы 24–72 — расследование

Установить причины, последовательность событий, лиц, чьи действия привели к инциденту. Определить меры, исключающие повторение.

Час 72 — итоговое уведомление

Направить сведения о результатах расследования по форме раздела 7.

После

Внести запись в журнал инцидентов. Реализовать корректирующие меры. При необходимости — пересмотреть определение угроз безопасности.

5. Взаимодействие с привлечёнными лицами

Договором с ООО «ИНТЕРФОНИКА» установлена обязанность уведомить Оператора **не позднее 6 часов** с момента выявления инцидента. Срок сокращён относительно законных 24 часов намеренно: он должен позволить Оператору уложиться в собственный срок перед Роскомнадзором.

При получении такого уведомления сроки, установленные разделом 3, исчисляются с момента получения уведомления Оператором.

6. Форма первичного уведомления (24 часа)

В Федеральную службу по надзору в сфере связи, информационных технологий и массовых коммуникаций

Уведомление об инциденте (пункт 1 части 3.1 статьи 21 Федерального закона от 27.07.2006 № 152-ФЗ)

Оператор: ФИО, ИНН, адрес, контакты. Дата и время выявления инцидента: __ Описание инцидента: __ *Предполагаемые причины, повлёкшие нарушение прав субъектов персональных данных:* __ *Предполагаемый вред, нанесённый правам субъектов персональных данных:* __ Категории персональных данных и ориентировочное количество субъектов: __ *Принятые меры по устранению последствий инцидента:* __ Лицо, уполномоченное на взаимодействие с уполномоченным органом по вопросам, связанным с выявленным инцидентом: ФИО, телефон, электронная почта.

Дата, подпись.

7. Форма итогового уведомления (72 часа)

Уведомление о результатах внутреннего расследования инцидента (пункт 2 части 3.1 статьи 21)

Ссылка на первичное уведомление: от __ Результаты внутреннего расследования: установленные причины, последовательность событий, затронутые данные и субъекты, факт доступа третьих лиц. Сведения о лицах, действия которых стали причиной выявленного инцидента (при наличии): __ *Принятые и планируемые меры, исключающие повторение:* __

Дата, подпись.

8. Журнал инцидентов

№	Дата и время выявления	Описание	Категории данных	Число субъектов	Уведомление 24 ч	Уведомление 72 ч	Меры	Статус

Журнал ведётся постоянно, включая события, не потребовавшие уведомления. **Наличие журнала с записями о событиях, разобранных и не признанных инцидентами, — самостоятельное доказательство добросовестности при проверке.**

9. Хранение

Материалы по каждому инциденту (уведомления, журналы, переписка, технические свидетельства) хранятся не менее 3 лет с даты завершения расследования.